

Detecting Quiet Adversaries in Risk-Adaptive Encryption: Hardening Drift Detection Against Mimicry and Low-and-Slow Traffic

Tarun Raja

[Affiliation]

[email]

Abstract—CipherWeave chooses a cipher profile for each agent request from a risk graph. When a behavioral-drift statistic fires, it overrides the choice to the strongest (post-quantum) profile. Its evaluation left an open problem: attackers who imitate the victim’s traffic, or move slowly, went largely undetected. We make four contributions. *First*, we find that the reported false-positive rate (FPR) depended on Python’s per-process hash salt. The same corpus gave a measured FPR of 2.1% or 6.9% at a 5% target, depending only on `PYTHONHASHSEED`. We make the calibration/test split stable, and we report Wilson intervals. *Second*, we add two channels to the detector’s max-combiner: inter-arrival regularity, and a long-horizon sensitive-data share whose baseline is kept disjoint from the window it tests. We prove when each fires (Lemma 1 and Theorem 1), and show that max-combination preserves each channel’s unilateral authority (Proposition 2). *Third*, we prove that an attacker whose traffic has the victim’s own distribution is caught at exactly the false-positive rate by *any* detector (Theorem 2), and we include such an attacker in a harder corpus. With realistic sensitive-data rates on benign traffic, the extended detector raises the area under the ROC curve (AUC) from 0.788 to 0.923 and catches low-and-slow, mimicry and jittered low-and-slow attackers at 100% (from 0–50%). The full-mimicry attacker stays at 10%, consistent with Theorem 2. The cost is a test FPR of 11% (95% CI 6.3–18.6%) at the 5% target, so the extension ships disabled. *Fourth*, we measure post-quantum costs with `liboqs 0.16.0`. A full round trip of ML-KEM-768, the module-lattice key-encapsulation mechanism (KEM), takes $36.7\ \mu\text{s}$ (median) and costs less than one X25519 exchange ($95.9\ \mu\text{s}$). The real cost of the strongest profile is 2.2 KiB of extra key material on the wire.

Index Terms—anomaly detection, mimicry attacks, post-quantum cryptography, ML-KEM, risk-adaptive encryption

I. INTRODUCTION

Risk-adaptive encryption selects cipher strength per request [1]. A behavioral override protects against a compromised agent whose risk-graph context still looks benign. The override fires when a drift statistic

$$\delta = \max(z_H, z_\lambda, z_{\text{mix}}) \quad (1)$$

exceeds θ . Here z_H is the standardized deviation of destination entropy, z_λ the one-sided deviation of request rate, and z_{mix} the Jensen–Shannon divergence [3] of the cipher-profile mix. All are computed over a trailing window against exponentially weighted moving-average (EWMA) baselines.

The earlier evaluation found that attackers drawing endpoints and profiles from the victim’s own history, at the victim’s own rate, moved none of these channels. This paper addresses that problem, and states precisely which part of it no detector of this kind can solve.

II. RELATED WORK

Mimicry attacks against host-based anomaly detectors were shown by Wagner and Soto [4]. Sommer and Paxson [5] and Axelsson [6] explain why low false-positive rates dominate the usefulness of network anomaly detection. Change detection for slow shifts traditionally uses CUSUM [7]. Our long-horizon channel is a windowed binomial test with a disjoint baseline. Public flow datasets such as CIC-IDS2017 [8] and UNSW-NB15 [9] provide recorded traffic. ML-KEM is standardized in FIPS 203 [10], and we measure it with the Open Quantum Safe library [11].

III. EVALUATION HYGIENE

The corpus has five benign archetypes, including two hard negatives (a bursty ETL job and an agent that onboards new endpoints), and six attack classes in corpus v1, including two designed to evade; corpus v2 (Section VI) adds two more, for eight. Episodes are split 50/50 into calibration and test. The threshold is the $(1 - \text{target})$ quantile of benign calibration scores, applied unchanged to the test split.

The split used Python’s `hash(agent_id)`, which is salted per process. With seeds 1 and 2, the same corpus and code gave AUC 0.894 vs. 0.922, and a measured FPR at the 5% target of 6.9% vs. 2.1%. A single reported FPR was therefore one draw of a number that moves by a factor of three. We now split by CRC-32 of the agent id, and report every FPR with a 95% Wilson interval [12], [13]. On the 100 benign test episodes, a 5% target is consistent with anywhere from roughly 2% to 11%.

IV. TWO LONGER-HORIZON CHANNELS

A. Inter-arrival regularity

For the gaps $g_1, \dots, g_{n-1}$ in the window, let $\hat{c} = \text{sd}(g)/\text{mean}(g)$. Its baseline (μ_c, σ_c) is an EWMA sampled

at a stride of a quarter window. The channel is one-sided, $z_{\text{reg}} = (\mu_c - \hat{c})^+ / \max(\sigma_c, 0.15\mu_c, \epsilon)$, so it fires only on traffic more regular than usual.

Lemma 1 (Regularity separates scripts from organic traffic). *If the gaps are i.i.d. exponential (a Poisson process), the population coefficient of variation is 1. If the gaps are gU with $U \sim \text{Unif}[1 - \epsilon, 1 + \epsilon]$ (a script sleeping g with jitter $\pm\epsilon$), it is $\epsilon/\sqrt{3}$.*

Proof. An exponential variable has equal mean and standard deviation. For gU , the mean is g and $\text{Var}(gU) = g^2(2\epsilon)^2/12$, so the standard deviation is $g\epsilon/\sqrt{3}$ and the ratio is $\epsilon/\sqrt{3}$. $\square$

The corpus's `low_and_slow` and `mimicry` attackers use $\epsilon \in \{0.10, 0.15\}$, giving $c \approx 0.06$ – 0.09 against about 1 for Poisson-like benign traffic. Bursty benign traffic has $c > 1$, and the channel ignores it because it is one-sided.

B. Long-horizon sensitive share

Let each request carry a flag for whether its data tags include PII, PHI, PCI or trade secrets. Over a long window W_L (twice the short window) holding n requests, let $\hat{p}$ be the fraction flagged. The baseline p_0 is a decayed mean (memory about 1000 events) fed *only* by events that have left W_L , and only by decisions not flagged as drift. The channel is

$$z_{\text{sens}} = \frac{(\hat{p} - p_0)^+}{\sqrt{\tilde{p}(1 - \tilde{p})/n}}, \quad \tilde{p} = \min(\max(p_0, 0.02), 0.98), \quad (2)$$

where the floor keeps an agent that has never touched sensitive data at a large but finite score.

Theorem 1 (A disjoint baseline cannot absorb the attack it is testing). *Suppose an attack starting at time t_0 raises the sensitive rate from p_0 to $p_1 > p_0$, with flags independent Bernoulli(p_t). For $t < t_0 + W_L$, the baseline equals its pre-attack value p_0 . If a fraction f of the n requests in W_L belong to the attack, then*

$$\mathbb{E}[\hat{p} - p_0] = f(p_1 - p_0), \quad \mathbb{E}[z_{\text{sens}}] \geq \frac{f(p_1 - p_0)\sqrt{n}}{\sqrt{\tilde{p}(1 - \tilde{p})}}. \quad (3)$$

In particular, once the window is fully inside the attack ($f = 1$), the expected score reaches θ as soon as $n \geq \theta^2 \tilde{p}(1 - \tilde{p})/(p_1 - p_0)^2$.

Proof. Only events older than $t - W_L$ reach the baseline. For $t < t_0 + W_L$ these all precede t_0 , so the baseline is exactly its pre-attack value. $\hat{p}$ is the mean of $n(1 - f)$ Bernoulli(p_0) and nf Bernoulli(p_1) flags, so $\mathbb{E}[\hat{p}] = p_0 + f(p_1 - p_0)$. For the score, $x \mapsto x^+$ is convex, so by Jensen's inequality $\mathbb{E}[(\hat{p} - p_0)^+] \geq (\mathbb{E}[\hat{p} - p_0])^+$. Dividing by the denominator, which depends only on p_0 and n and so is deterministic, gives the bound. The threshold condition follows by setting $f = 1$ and solving $\sqrt{n}(p_1 - p_0)/\sqrt{\tilde{p}(1 - \tilde{p})} \geq \theta$. $\square$

Remark 1 (Why disjointness matters). The first version of this channel updated p_0 on every event, including events inside the window. Under a sustained attack, p_0 then moves toward p_1

with every attack event, while $\hat{p}$, averaged over a long window, still contains mostly pre-attack events. So $\hat{p} - p_0 \leq 0$ for a long stretch, and the channel reported zero. A unit test caught this: a rise from 10% to 60% sensitive share went undetected. Theorem 1 is the property the redesign guarantees.

Proposition 1 (Null behavior). *Under no attack, with flags i.i.d. Bernoulli(p_0) and p_0 inside the floor range, z_{sens} converges in distribution to $\max(Z, 0)$ for $Z \sim \mathcal{N}(0, 1)$ as $n \rightarrow \infty$. So $\Pr(z_{\text{sens}} \geq 3) \rightarrow 1 - \Phi(3) \approx 0.00135$ per evaluation.*

Proof. This is the central limit theorem for $\hat{p}$ with the true variance $p_0(1 - p_0)/n$, followed by the continuous mapping $x \mapsto x^+$. $\square$

The per-evaluation rate is small, but the detector is evaluated at every request of an episode. The per-episode false-positive rate is therefore the probability that a maximum over hundreds of correlated tests exceeds θ . That is much larger, and it is why the empirical FPR in Section VII can exceed the target.

C. Combination

Proposition 2 (Max-combination preserves unilateral authority). *Let $\delta = \max_i z_i$ over channels $i = 1, \dots, k$. Then $\delta \geq \theta$ iff some $z_i \geq \theta$. An attacker evades only by keeping every channel below θ . In contrast, under a weighted mean $\bar{z} = \sum_i w_i z_i$ with $\sum_i w_i = 1$, an attacker who holds $k - 1$ channels at 0 evades whenever $z_j < \theta/w_j$ on the remaining channel, which is a factor $1/w_j$ looser.*

Proof. Both claims follow directly from the definitions of $\max$ and of the weighted mean. $\square$

Taking the maximum is legitimate here because every channel is computed by the same detector on the same agent's traffic and scaled to the common threshold θ . Most channels are standardized deviations; z_{mix} is not, but is a Jensen–Shannon divergence divided by a fixed scale $\tau = 0.25$, chosen so that a near-total flip of the profile mix clears θ . Each channel's value is therefore read on the same scale, relative to θ , by design. Rule R3 of our score-contract work forbids a maximum across *producers*, where no common scale exists [2]. The detector's output δ is itself one such producer's score, and is declared there as a risk indicator.

V. THE DETECTABILITY BOUND

Theorem 2 (Distributional mimicry is undetectable). *Let X be everything a detector observes about an agent over an episode. Let P_0 be its law under benign operation and P_1 its law under attack. If $P_1 = P_0$, then every detector D (any measurable function of X into $\{\text{alarm}, \text{no alarm}\}$, possibly randomized independently of X) satisfies $\Pr_{P_1}[D = \text{alarm}] = \Pr_{P_0}[D = \text{alarm}]$. Its true-positive rate equals its false-positive rate.*

Proof. $\Pr_P[D = \text{alarm}] = \int \Pr[D(x) = \text{alarm}] dP(x)$, where the inner probability accounts for D 's own randomness. The integrand is the same function under P_0 and P_1 , and the measures are equal. $\square$

TABLE I

DISCRIMINATION AND CALIBRATED FALSE-POSITIVE RATE (TEST SPLIT).
FPR AT A 5% TARGET ON BENIGN CALIBRATION, WITH 95% WILSON CI.

Detector	Corpus	AUC	FPR (95% CI)
Eq. (1)	v1	0.909	4.0% (1.6–9.8)
extended	v1	1.000	4.0% (1.6–9.8)
Eq. (1)	v2	0.788	7.0% (3.4–13.7)
extended	v2	0.923	11.0% (6.3–18.6)

TABLE II

DETECTION RATE OF δ ON CORPUS v2 AT THE 5% OPERATING POINT,
WITH THE CHANNEL THAT MOST OFTEN FIRED.

Attack	Eq. (1)	extended (channel)
exfil_burst	100%	100% (sens.)
beacon	100%	95% (entropy)
scan	100%	100% (entropy)
downgrade	10%	100% (sens.)
low_and_slow	30%	100% (sens.)
mimicry	50%	100% (sens.)
low_and_slow_jittered	0%	100% (sens.)
mimicry_full	10%	10% (rate)

The corpus attacker `mimicry_full` resamples the victim’s empirical joint distribution of endpoint, profile and tags, and its empirical inter-arrival gaps. It approximates $P_1 = P_0$ up to finite-sample differences. Theorem 2 predicts that its detection rate matches the false-positive rate, and the measured rate is consistent with that prediction (Section VII). Catching such an attacker requires information outside X : payload, identity, or whether the agent is *authorized* to reach an endpoint at all. CipherWeave enforces authorization deterministically in the risk graph, not statistically.

VI. CORPUS v2

On the original corpus (v1), benign traffic never carries a sensitive tag and every evasive attack does, so a sensitive-share channel wins trivially: its AUC is 1.000. Corpus v2 closes that gap before measuring anything:

- benign archetypes carry sensitive data at archetype-specific rates (2–45%), using a non-CHEAP profile for it as a correctly configured agent would;
- `low_and_slow_jittered` uses Poisson gaps at the victim’s mean rate, so regularity cannot see it;
- `mimicry_full` realizes Theorem 2.

The v2 sensitive-data rates are assumptions, not measurements.

VII. RESULTS

Settings: 40 episodes per class, so the test split holds 100 benign episodes and 20 per attack class; a 300 s window, $n_{\min} = 20$, and thresholds set on benign calibration episodes at a 5% target (Table I).

What the numbers say. The harder benign traffic of v2 costs Eq. (1) 0.12 AUC by itself (Table I). The extended detector recovers it and more. Table II gives detection by attack class. The extended detector catches `low_and_slow`, `mimicry`, `low_and_slow_jittered` and `downgrade`

TABLE III

MEDIAN / P99 LATENCY (μ s) AND WIRE SIZES.

Operation	median	p99
X25519 keygen+exch. (both sides)	95.9	151.0
P-256 keygen+exch. (both sides)	78.9	122.7
ML-KEM-512 full round trip	28.1	48.8
ML-KEM-768 keygen/enc/dec	8.6 / 9.7 / 10.2	
ML-KEM-768 full round trip	36.7	65.3
ML-KEM-1024 full round trip	44.7	69.3
Hybrid X25519+ML-KEM-768 (prod.)	218.7	305.8
HKDF-SHA256 $\rightarrow$ 32 B	3.8	9.0
HKDF-SHA512 $\rightarrow$ 32 B	5.4	16.7
AES-256-GCM, 64 KiB	7.2	30.1
ML-KEM-768 public key / ciphertext	1184 / 1088 B	
X25519 public key		32 B

at 100%, up from 0–50%. `beacon` detection falls from 100% to 95%. The beacon is still caught by the entropy channel, but the extended detector’s calibrated threshold is higher (3.74 vs. 3.15), and one of the 20 test beacon episodes fell below it. Consistent with Theorem 2, `mimicry_full` is caught at about the false-positive rate: 10% against 7–11%. The cost is false positives: 11% at the 5% target, with new alarms on the *expanding* (15%) and *steady_batch* (5%) archetypes. The threshold is calibrated on 100 benign episodes, and the extended score’s heavier benign tail transfers worse. We therefore ship the extension *disabled*, pending a larger calibration set or per-channel thresholds.

Recorded traffic. A loader maps CICFlowMeter CSVs (CIC-IDS2017 [8]) to host episodes: source IP as the agent, destination IP:port as the endpoint, and a protocol-derived profile. Flow records carry no data-sensitivity label, so there the sensitive-share channel is inert by construction, and only the regularity channel is tested. The loader is released and tested on synthetic CSVs; evaluation on the recorded datasets is future work.

VIII. POST-QUANTUM COST

We measured every primitive the profiles use, through the same libraries as the production code (Table III). Setup: Linux x86_64, Python 3.12.3, OpenSSL 4.0.2, liboqs 0.16.0; 1,000 iterations after warm-up.

A full ML-KEM-768 round trip costs less than a single X25519 exchange. The QUANTUM_SAFE profile’s real cost is about 2.2 KiB more key material per establishment. The production hybrid path takes 219 μ s, more than its primitives combined (about 37 + 96 μ s). The extra time is overhead around the cryptography, from object construction and key re-parsing. At a fifth of a millisecond it does not threaten the service’s 10 ms p99 budget. Symmetric differences between profiles are a few microseconds.

IX. LIMITATIONS

The corpus is synthetic, and the v2 sensitive-data rates are assumptions. Theorem 1 is about the expected score; tail behavior under autocorrelated traffic is not analyzed. The

extended detector’s false-positive cost is not yet acceptable for fail-secure deployment.

X. CONCLUSION

Two longer-horizon channels close the mimicry gap for the low-and-slow, jittered low-and-slow, mimicry and downgrade attackers in our corpus, which are scripts, or are after sensitive data, or both. A disjoint baseline is what keeps the slow attacker from teaching the detector to ignore it. The attacker these channels miss is one no traffic-only detector can catch, and we prove it. Post-quantum key establishment is cheap in CPU and costs bandwidth.

REFERENCES

- [1] T. Raja, [title of the CipherWeave risk-adaptive encryption paper], [venue, year].
- [2] T. Raja, “Not all scores are probabilities: Typed, calibrated confidence contracts for composed agent systems,” companion paper, [venue, year].
- [3] J. Lin, “Divergence measures based on the Shannon entropy,” *IEEE Trans. Inf. Theory*, vol. 37, no. 1, pp. 145–151, 1991.
- [4] D. Wagner and P. Soto, “Mimicry attacks on host-based intrusion detection systems,” in *Proc. ACM CCS*, 2002, pp. 255–264.
- [5] R. Sommer and V. Paxson, “Outside the closed world: On using machine learning for network intrusion detection,” in *Proc. IEEE S&P*, 2010, pp. 305–316.
- [6] S. Axelsson, “The base-rate fallacy and the difficulty of intrusion detection,” *ACM Trans. Inf. Syst. Secur.*, vol. 3, no. 3, pp. 186–205, 2000.
- [7] E. S. Page, “Continuous inspection schemes,” *Biometrika*, vol. 41, pp. 100–115, 1954.
- [8] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proc. ICISP*, 2018, pp. 108–116.
- [9] N. Moustafa and J. Slay, “UNSW-NB15: A comprehensive data set for network intrusion detection systems,” in *Proc. MilCIS*, 2015, pp. 1–6.
- [10] NIST, “Module-lattice-based key-encapsulation mechanism standard,” FIPS 203, 2024.
- [11] D. Stebila and M. Mosca, “Post-quantum key exchange for the Internet and the Open Quantum Safe project,” in *Proc. SAC*, 2016, pp. 14–37.
- [12] E. B. Wilson, “Probable inference, the law of succession, and statistical inference,” *J. Amer. Statist. Assoc.*, vol. 22, pp. 209–212, 1927.
- [13] L. D. Brown, T. T. Cai, and A. DasGupta, “Interval estimation for a binomial proportion,” *Statist. Sci.*, vol. 16, no. 2, pp. 101–133, 2001.